Phát hiện botnet IoT bằng autoencoder nhẹ

Đề tài DT043 · Bài giữa kỳ An toàn Bảo mật Hệ thống thông tin

Hoàng Thanh Trà · MSSV 1150080120 · Lớp 11CNPM2

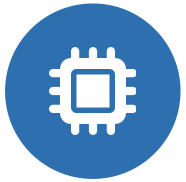
Per-device AE · lượng tử hóa int8 · edge benchmark · MTD lai

Bài toán: phát hiện botnet ngay tại edge



Thiết bị IoT dễ bị chiếm

Mật khẩu mặc định, ít vá – Mirai, BASHLITE chiếm hàng loạt để DDoS



Edge có tài nguyên hạn chế

Bộ phát hiện phải nhỏ (KB), nhanh (µs), ít RAM và năng lượng



Mỗi thiết bị một hành vi

Học benign riêng từng thiết bị, cảnh báo khi lỗi tái tạo tăng

Câu hỏi nghiên cứu

- RQ1 Tái lập baseline Meidan 2018
- RQ2 Per-device có hơn model chung?
- RQ3 AE nhẹ giữ chất lượng?
- RQ4 int8 + hiệu chỉnh ngưỡng
- RQ5 Chạy được trên edge?
- RQ6 AE kích hoạt MTD lai

Tiêu chí thành công chốt trước khi chạy (SHA-256 ghi trong nhật ký)

Paper chính nói về MTD → chiến lược hai track

Masud et al. (2025, Computers & Security) – hybrid Moving Target Defence + mô hình đồ thị tấn công 3-layer THARM; không dùng autoencoder, N-BaIoT hay edge.

Track A · lõi · ~70%

- Per-device AE trên N-BaIoT
- Baseline: Meidan 2018
- Model nhẹ + int8 + hiệu chỉnh ngưỡng
- Edge benchmark

Track B · cầu nối · ~30%

- Tái lập xu hướng MTD: shuffle / diversity / kết hợp
- Mô hình HARM rút gọn
- MTD lai: cảnh báo AE kích hoạt move

Cầu nối: cửa sổ cảnh báo của AE (Track A) là sự kiện kích hoạt MTD event-based (Track B)

Dữ liệu N-BaIoT: lớn, trùng lặp và mất cân bằng

7.06M

dòng (UCI, CC BY 4.0)

115

đặc trưng = 23 thống kê × 5 cửa sổ

9

thiết bị IoT thương mại

10

kiểu tấn công Mirai + BASHLITE

157,779

dòng trùng lặp chính xác bị loại (benign Danmini 18.5%; gafgyt tcp/udp). Còn 6,904,827 dòng; manifest SHA-256 cho 107 file.

5.5–61.8×

attack nhiều hơn benign → Accuracy vô nghĩa; metric chính là macro-F1 và FPR mức cửa sổ, kèm F1 khi test cân bằng.

Chống rò rỉ: chia theo thời gian, có vùng đệm

DStrn · train AE + fit scaler | **DSopt · ngưỡng tr*, cửa sổ ws*** | **Test benign + mọi tấn công**

← thứ tự thời gian của benign (1/3 · 1/3 · 1/3 như Meidan); khoảng trắng giữa các khối = 500 dòng đệm bị bỏ →

0.20–0.86

tự tương quan bậc 1 của benign theo thứ tự gốc (xáo trộn: ≈ 0.00) → chia ngẫu nhiên sẽ rò rỉ

- Khử trùng lặp trong từng file
- Scaler fit chỉ trên DStrn, gắn tên thiết bị
- Ngưỡng/cửa sổ chỉ từ DSopt benign
- Vote không vượt ranh giới file
- Đối chứng E6: cố tình làm sai để đo sai lệch

Pipeline và các mô hình so sánh



Mô hình	Kiến trúc	Tham số	Vai trò
B0	115-86-58-38-29-…-115	36,876	Baseline Meidan, per-device
B1	B0 dùng chung 9 thiết bị	36,876	Kiểm tra giả thuyết per-device
B2	Isolation Forest	–	Baseline không phải NN
V1	115-32-8-32-115	8,059	AE nhẹ (21.9% tham số)
V2	23-12-4-12-23 × 5 cửa sổ	~700	Bớt cả đặc trưng

Hệ thống demo tách 4 tầng: AI · BE · DB · FE



AI

ai/ – huấn luyện, đánh giá, lượng tử hóa, benchmark, xuất gói triển khai



Backend

FastAPI – nạp gói (kiểm SHA-256), suy luận TFLite 1 luồng, API detect/replay/alerts/MTD



Database

SQLite – devices, models, detection_batches, alerts, mtd_actions, experiment_results

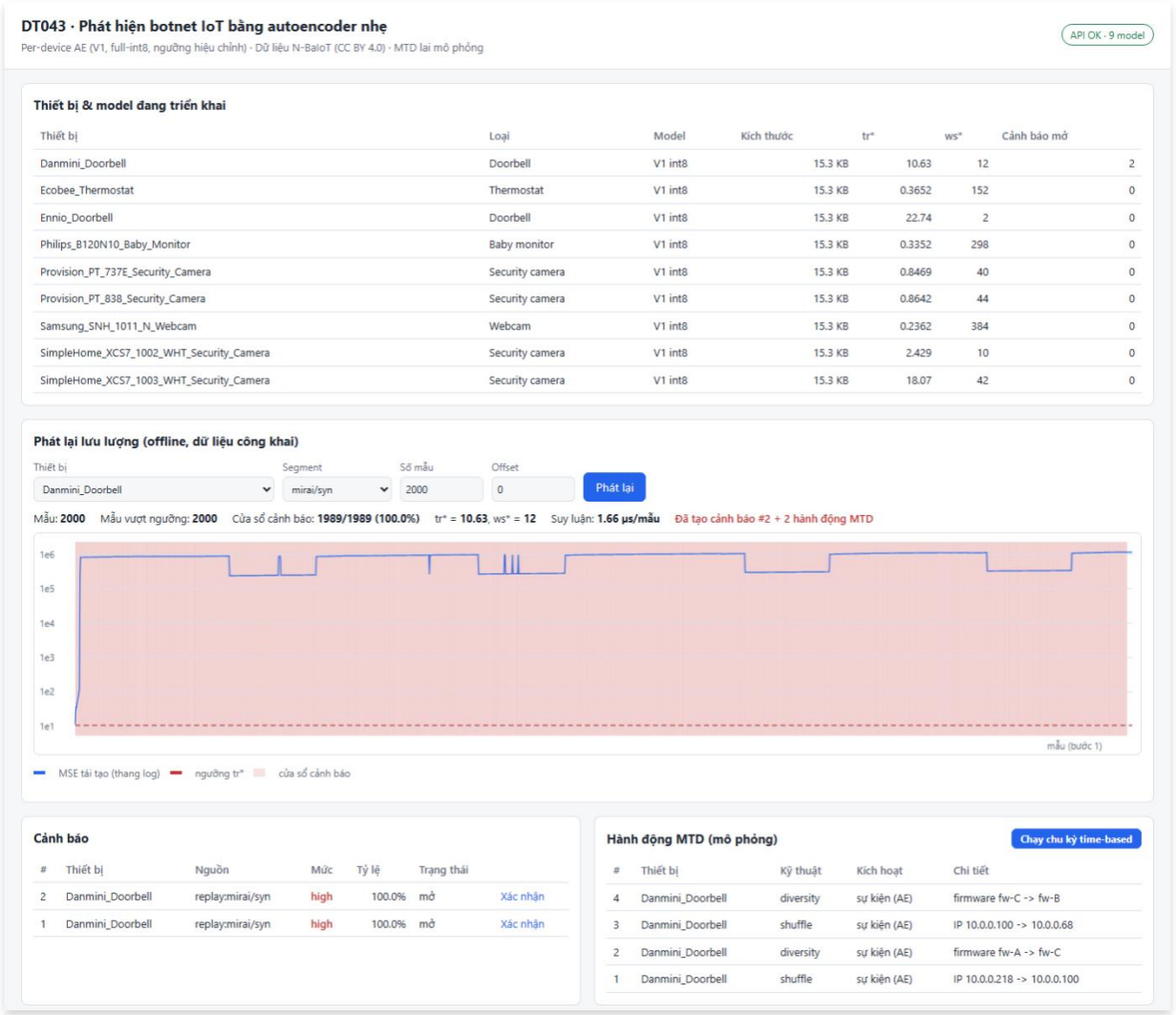


Frontend

Dashboard HTML/JS – thiết bị, phát lại lưu lượng, biểu đồ MSE, cảnh báo, nhật ký MTD

Hợp đồng AI → BE: artifacts/deploy/<thiết bị>/{model.tflite, scaler.json, meta.json} · 42 test tự động (30 AI + 12 BE/DB)

Demo: phát hiện + cảnh báo + MTD trên dashboard



mirai/syn (Danmini)

100% cửa sổ cảnh báo → cảnh báo mức high + shuffle IP + đổi firmware (event-based)

benign (phần test)

Không cảnh báo, không move vô ích

gafgyt/tcp (Ennio)

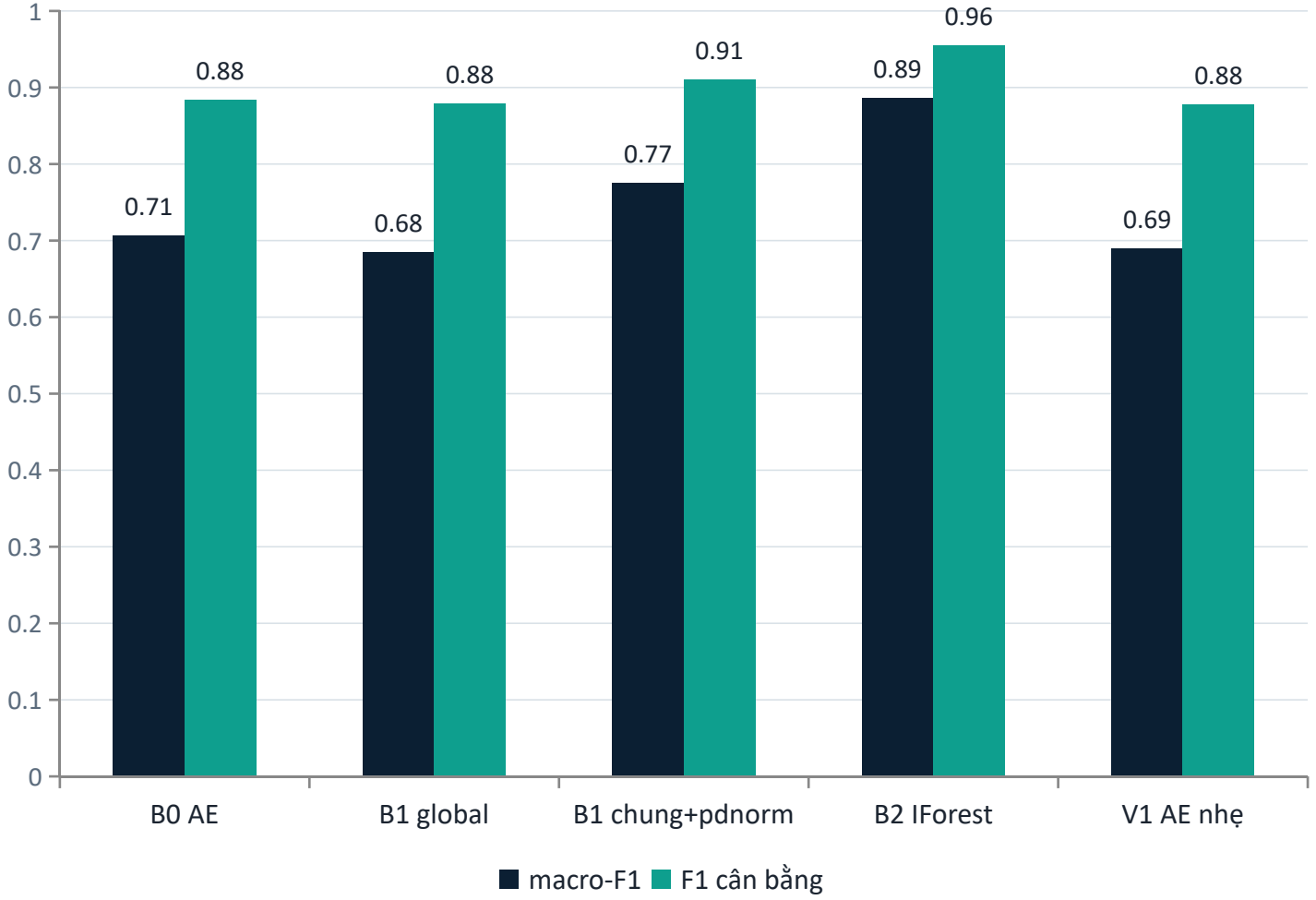
Không vượt ngưỡng – đúng lỗi bỏ sót đã phân tích

Suy luận V1 int8

Vài µs/mẫu, 1 luồng; mọi lô ghi vào SQLite

Mở: http://127.0.0.1:8000/?replay=Danmini_Doorbell:mirai/syn

Kết quả tổng quan (mức cửa sổ, 9 thiết bị × seed)



0.0025

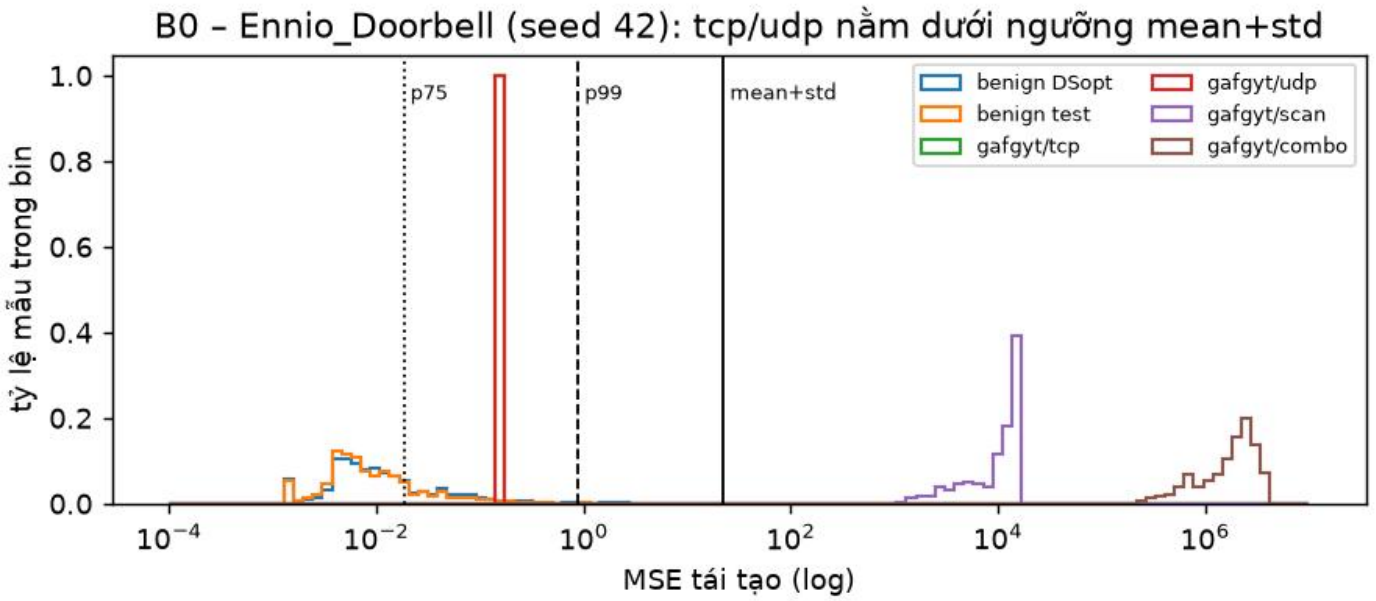
FPR của B0 – thấp hơn Meidan (0.007)

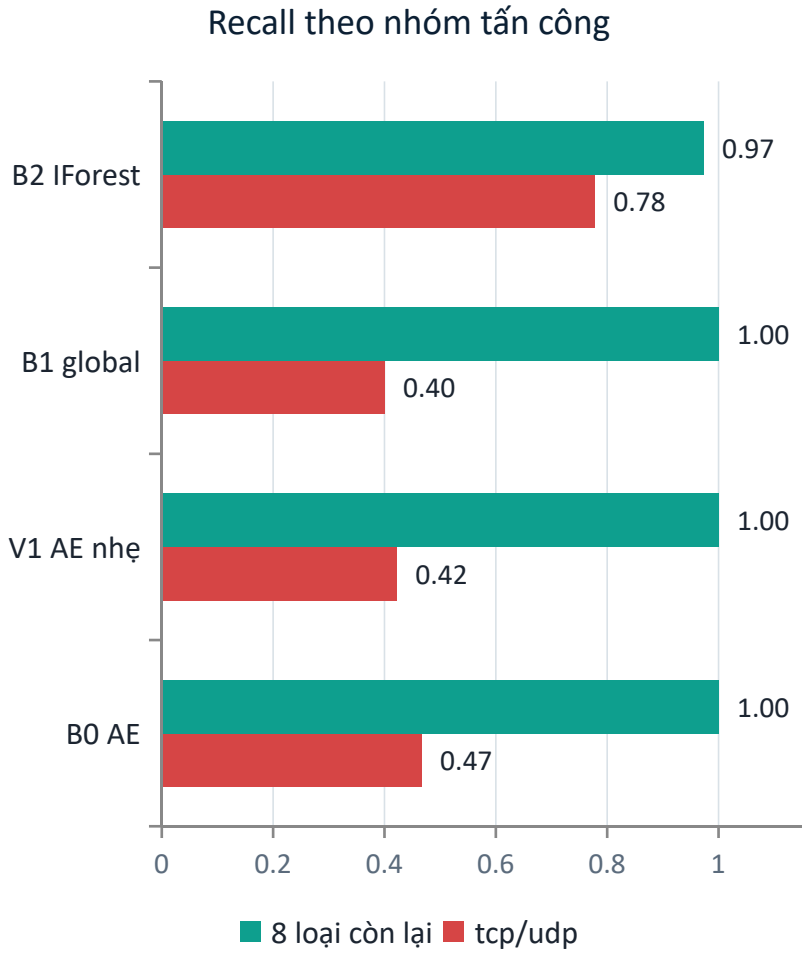
0.822

TPR của B0 – không đạt 100% như paper

ROC-AUC mức mẫu vẫn > 0.99: điểm MSE phân tách tốt, vấn đề nằm ở ngưỡng.

Lỗi chính: flood BASHLITE tcp/udp trông giống benign





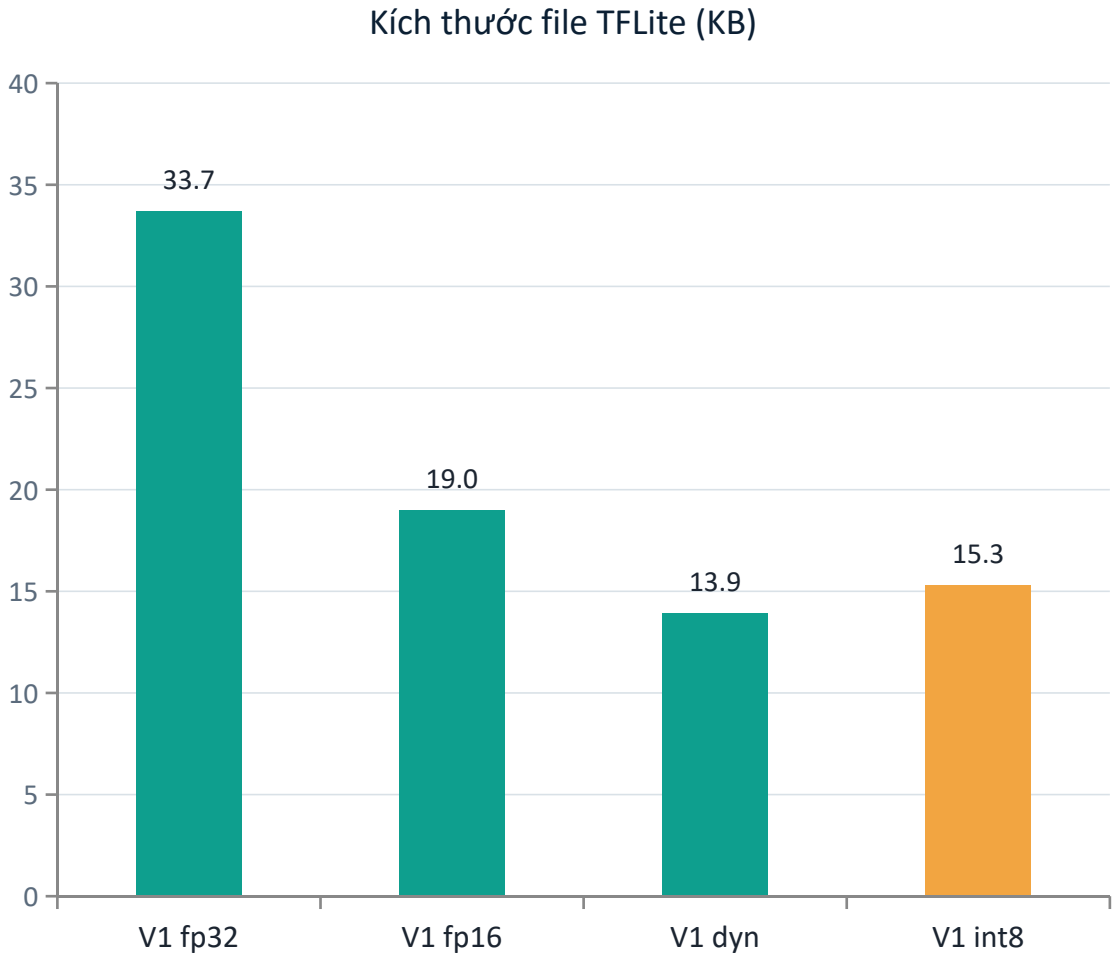
Nguồn bị giả mạo liên tục → mỗi gói như "luồng mới": weight = 1, variance = 0, 60 byte. MSE ≈ 0.17 – trên phần lớn benign nhưng dưới ngưỡng mean+std bị đuôi phân phối kéo lên.

Hậu kiểm: hạ ngưỡng bắt được tcp/udp nhưng phải trả giá

Ngưỡng mean+std (gốc)		Ngưỡng p75 của DSopt	
macro-F1	**0.686**	macro-F1	**0.995**
Recall tcp/udp	**0.44**	Recall tcp/udp	**1.00**
FPR test	**0.0023**	FPR test	**0.0203**
Cửa sổ ws*	**164 mẫu**	Cửa sổ ws*	**1410 mẫu**

Phân tích khám phá làm SAU khi xem test (V1, seed 42) → chỉ để giải thích, không tuyên bố cải tiến. FPR = 0 trên DSopt nhưng tăng trên test: benign trôi theo thời gian.

Lượng tử hóa: nhỏ hơn, và cần hiệu chỉnh lại ngưỡng



int8: giữ ngưỡng fp32 → hiệu chỉnh trên DSopt

FPR	**0.0030 → 0.0016**
Cửa sổ ws*	**153 → 113**
macro-F1	**0.751 → 0.717**

Hiệu chỉnh giảm FPR và độ trễ, nhưng macro-F1 giảm: khi giữ ngưỡng cũ, nhiễu int8 "vô tình" đẩy tcp/udp vượt ngưỡng.

Edge benchmark: V1 int8 trên một lõi E-core

10.8 µs

p95 latency / mẫu (ngưỡng 1000 µs)

15.3 KB

file model (ngưỡng 50 KB)

4.6 MB

RAM tăng thêm khi nạp + chạy

102,899

mẫu/giây trên 1 lõi

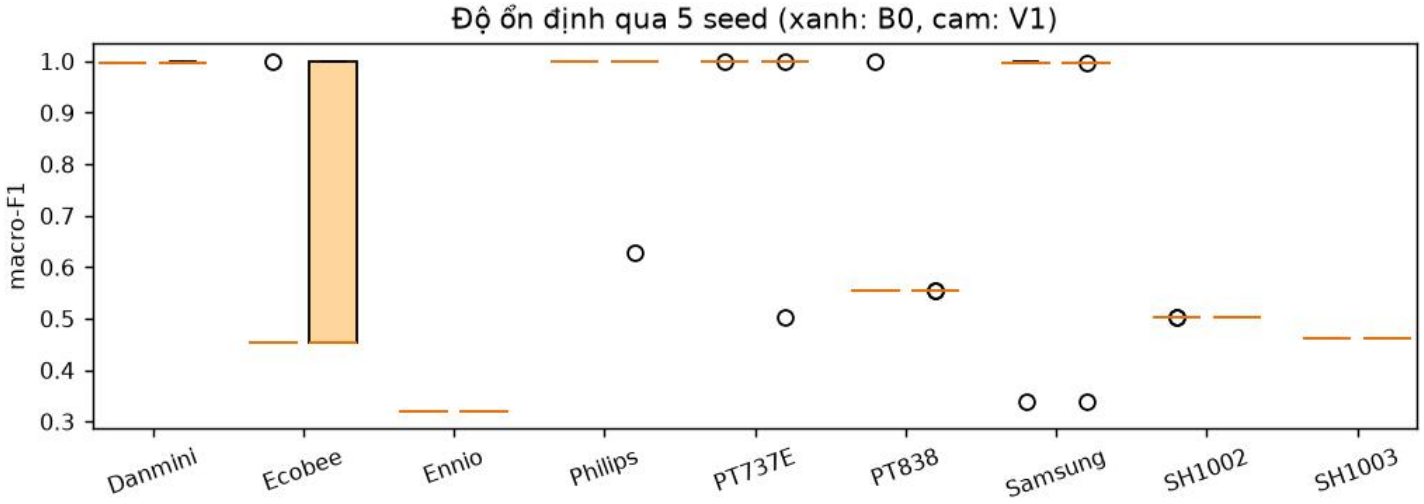
Đa luồng làm chậm model nhỏ

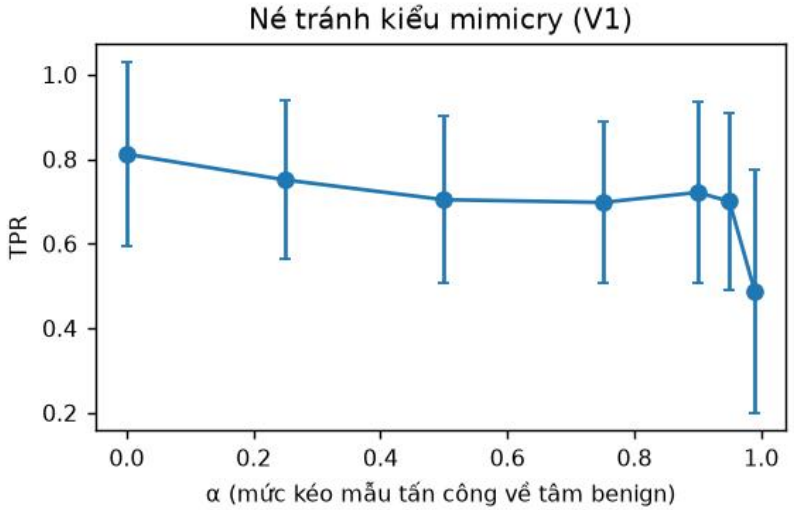
Batch 1 với 20 luồng: p50 473 µs, so với 9.0 µs khi 1 luồng ghim E-core → trên edge nên chạy đơn luồng.

Energy proxy & giới hạn

≈ 40.5 µJ/mẫu (CPU-time × 55 W/14 lõi), 7,872 MAC/mẫu. Không có Raspberry Pi: lõi E-core laptop mạnh hơn CPU edge thật.

Độ ổn định theo seed và robustness



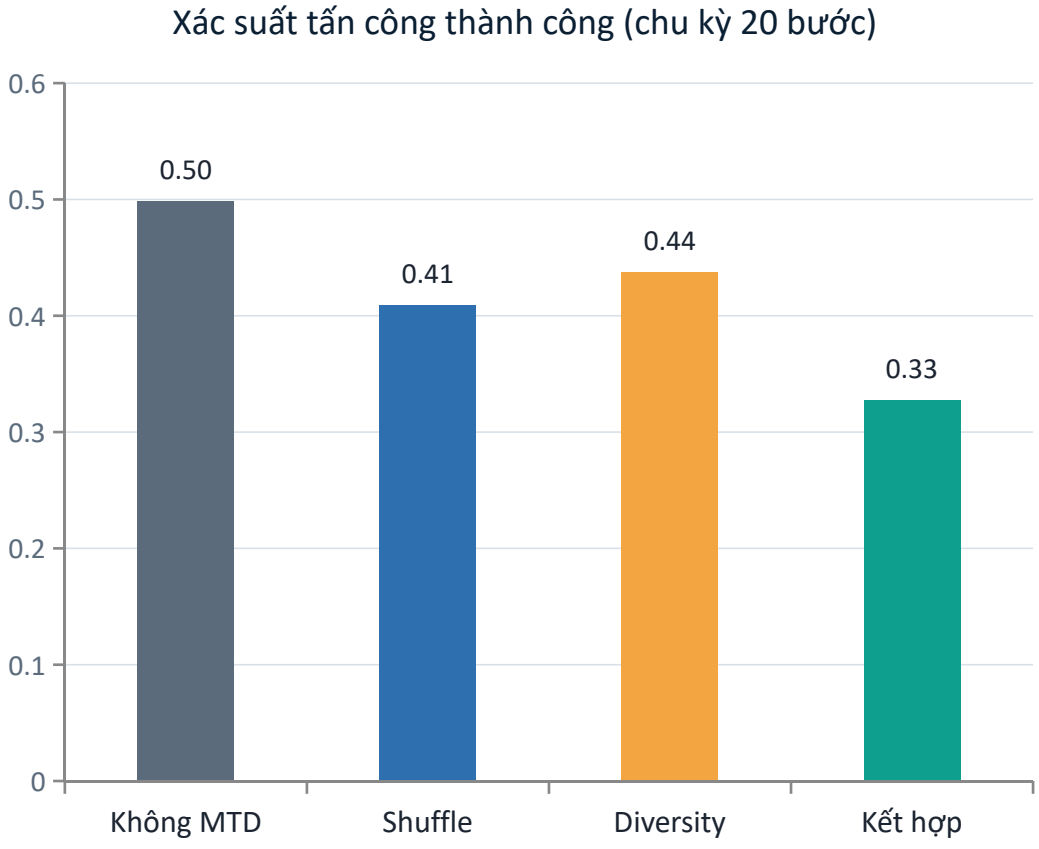


7 cặp (model, thiết bị) có TPR dao động > 0.05 chỉ vì đổi seed – một lần chạy như Meidan là không đủ.

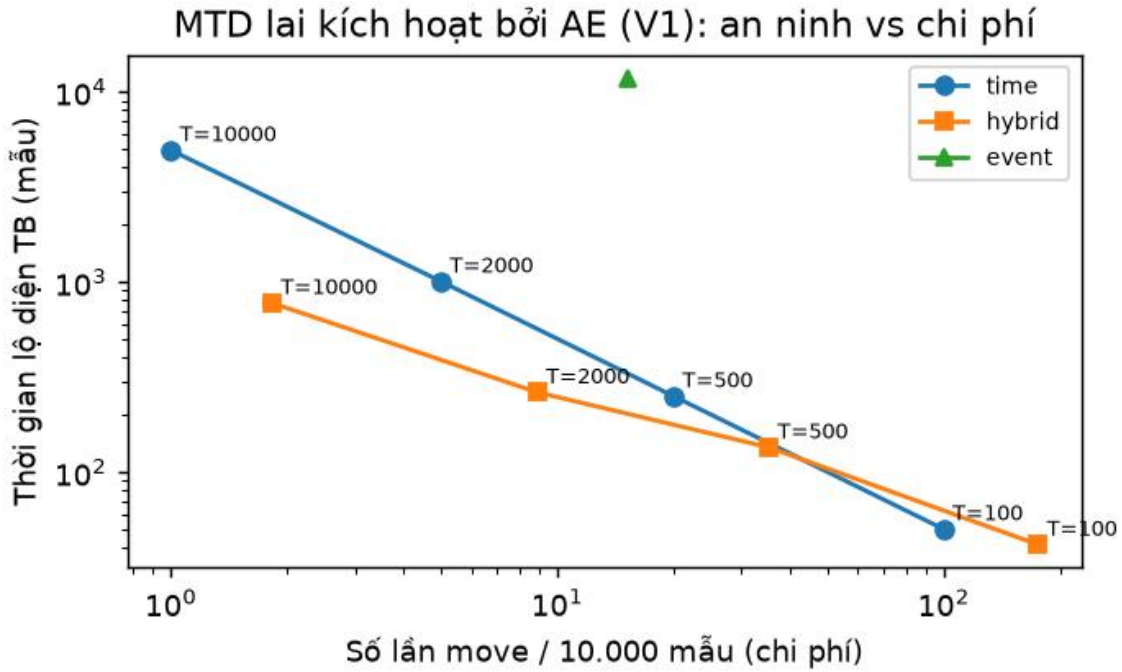
Né tránh: kéo mẫu tấn công về tâm benign; phải bắt chước rất sát (α lớn) mới né được – tức là phải giảm cường độ tấn công.

Báo cáo mean ± std, KTC95 và Wilcoxon thay vì con số tốt nhất.

MTD: tái lập xu hướng và MTD lai kích hoạt bởi AE



Khớp xu hướng paper chính: kết hợp shuffle + diversity thấp nhất.



Cùng chi phí, hybrid lộ diện ít hơn time-based. Chỉ event-based: lộ diện TB 11,835 mẫu vì tấn công AE bỏ sót không kích hoạt move → time-based là lưới an toàn.

Đối chiếu tiêu chí đã chốt trước

RQ	Tiêu chí	Giá trị đo	Kết luận
RQ1	TPR ≥ 0.99 và FPR ≤ 0.02 (B0)	TPR=0.8222, FPR=0.0025	**Không đạt**
RQ2	B0 > B1 ở ≥7/9 thiết bị và $p < 0.05$	thắng 4/9, p=0.2852	**Không đạt**
RQ3	V1 ≤ 25% tham số và Δmacro-F1 ≤ 0.01	tham số 21.9%, Δ=+0.0171	**Không đạt**
RQ4	int8+recal: Δmacro-F1 ≤ 0.005 và kích thước ≤ 30% fp32 (V1)	Δ=-0.0278, kích thước 45.5%	**Không đạt**
RQ5	P1: p95 ≤ 1 ms, model ≤ 50 KB, RSS tăng ≤ 50 MB (V1 int8)	p95=10.8 µs, 15.3 KB, ΔRSS=4.6 MB	**Đạt**

Không chỉnh tiêu chí sau khi có kết quả; mọi lần chạy (468) đều được báo cáo.

Kết luận & hướng phát triển

- AE per-device bắt gần tuyệt đối 8/10 loại tấn công với FPR rất thấp; bỏ sót flood tcp/udp giả mạo nguồn
- V1 int8 < 20 KB, vài µs/mẫu trên 1 lõi E-core – khả thi cho edge
- Kết quả dao động theo seed → cần nhiều lần chạy và kiểm định
- MTD: kết hợp shuffle + diversity tốt nhất; MTD lai dùng cảnh báo AE giảm thời gian lộ diện
- Tiếp theo: chọn ngưỡng có kiểm định trên dữ liệu mới · Raspberry Pi + đo điện thật · đặc trưng cho flood giả mạo